

Cybersecurity Daily Newsletter

Vol. 005 | 2026-09-15 09:00 WIB

Top 5 Highlights

- HBO Max Reddit account compromised to serve ClickFix attacks
- 'Sandworm' Chains Cisco Vulnerabilities to Deploy Cyclops Blink
- Japan's Digital Agency says VPN flaw exposed 246,000 personnel records
- Maximum Severity GitLab Flaw Puts Supply Chains at Risk
- Homebrew 7.0.0 gets built-in GUI, better security controls

Threat Intelligence (10)

01. HBO Max Reddit account compromised to serve ClickFix attacks

Part of a 'massive 48-hour malvertising blitz' targeting macOS and Windows machines with malware

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.theregister.com/cyber-crime/2026/09/14/hbo-max-reddit-account-compromised-to-serve-clickfix-attacks/5296408>

02. 'Sandworm' Chains Cisco Vulnerabilities to Deploy Cyclops Blink

The notorious Russian threat group is spreading an upgraded version of the botnet malware, which the FBI disrupted in 2022.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.darkreading.com/cyberattacks-data-breaches/sandworm-chains-cisco-vulnerabilities-cyclops-blink>

03. Hackers hijack HBO Max Reddit account to push malware in ClickFix ads

Hackers compromised HBO Max's official Reddit account and used it to push malicious ads that launched ClickFix attacks to infect Windows and macOS devices with information-stealing malware. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/hackers-hijack-hbo-max-reddit-account-to-push-malware-in-clickfix-ads/>

04. 3BB Attacker Used MeshCentral Backdoor for Root Access, Targeted Subscriber Credentials

An attacker was operating inside the network of 3BB, one of Thailand's largest broadband providers, and maintained remote control of internal machines using a legitimate management tool called MeshCentral, threat intelligence firm Hunt.io said. The company uncovered the intrusion by examining a server the attacker had left open on the internet, which held t...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/09/3bb-attacker-used-meshcentral-backdoor.html>

05. Hackers target exposed Vite dev servers to steal AWS, Azure secrets

A mass-scanning campaign targeting internet-exposed Vite development servers is attempting to steal cloud credentials and configurations from AWS and Azure deployments. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/hackers-target-exposed-vite-dev-servers-to-steal-aws-azure-secrets/>

06. [+24h Old] UK.gov begins killing off passwords for 23 million users

Passkeys promise fewer phishing headaches - and £600 a day off Whitehall's SMS bill

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.theregister.com/security/2026/09/14/ukgov-begins-killing-off-passwords-for-23-million-users/5296088>

07. [+24h Old] How to level up from security pro to security leader

There comes a time in a cybersecurity professional's life when being a tech expert is no longer enough. The next step may lead to management or the C-suite, but the goal demands a different kind of expertise. Technical skills will continue to serve a new CISO well, but the role demands additional capabilities built on that foundation. That may mean priorit...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources:

<https://www.csoonline.com/article/4221303/how-to-level-up-from-security-pro-to-security-leader.html>

08. [+24h Old] ISC Stormcast For Monday, September 14th, 2026

<https://isc.sans.edu/podcastdetail/10092>, (Mon, Sep 14th)

ISC Stormcast For Monday, September 14th, 2026

<https://isc.sans.edu/podcastdetail/10092>, (Mon, Sep 14th)

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://isc.sans.edu/diary/rss/33334>

09. [+48h Old] OpenAI Agents Linked to RubyGems Campaign That Gained RCE on RubyDoc Servers

The "major malicious attack" that targeted RubyGems in May 2026 was the work of a swarm of OpenAI agents, according to a new report published by researchers Spencer Kitts, Thomas Larsen, and Sydney Von Arx. On May 12, Maciej Mensfeld, senior product manager for software supply chain security at Mend.io, disclosed details of a coordinated cyber attack that t...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://thehackernews.com/2026/09/openai-agents-linked-to-rubygems.html>

10. [+48h Old] 9/11 at 25, OfferLoader, Gemini CLI, Liquid, 10% Doom, Josh Marpet, and More - SWN #615

9/11 at 25, OfferLoader, Gemini CLI, Liquid, 10% Doom, Josh Marpet, and More - SWN #615

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.scworld.com/podcast-segment/15298-9-11-at-25-offerloader-gemini-cli-liquid-10-doom-josh-marpet-and-more-swn-615>

Latest Vulnerabilities (10)

01. Maximum Severity GitLab Flaw Puts Supply Chains at Risk

CVE-2026-85706 is a path traversal vulnerability with a 10 out of 10 CVSS score, affecting both GitLab Community Edition and Enterprise Edition instances.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.darkreading.com/cyberattacks-data-breaches/maximum-severity-gitlab-flaw-supply-chains-risk>

02. Homebrew 7.0.0 gets built-in GUI, better security controls

Homebrew package manager version 7.0.0 has been released with a built-in vulnerability scanner, stronger security controls, and the full release of its native BrewUI graphical interface. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/homebrew-700-gets-built-in-gui-better-security-controls/>

03. Apple Updates Everything, (Mon, Sep 14th)

Today, Apple released its annual update across all its operating systems. With that, Apple not only released new features but also patched 261 different vulnerabilities. This is the most vulnerabilities Apple has ever patched, but the increase is not as significant as other vendors'; "post-AI" patch releases.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://isc.sans.edu/diary/rss/33336>

04. Telegram Desktop Flaw Lets Hidden JavaScript Exfiltrate Messages From HTML Exports

A flaw in Telegram Desktop let a bot's message plant hidden JavaScript inside chats that users exported to HTML files, security researchers at ExPatch said in a writeup published on September 12. In Telegram, the message looked ordinary, with a link button, and the script ran only when someone opened the export file in a web browser. It could then copy ever...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/09/telegram-desktop-flaw-lets-hidden.html>

05. Red Heron Exploits Gitea RCE to Compromise 13 Organizations Across Six Countries

A suspected Chinese threat actor tracked as Red Heron has been attributed to the rapid exploitation of a recently disclosed security vulnerability in Gitea to compromise internet-facing instances as part of a multi-national campaign. "Red Heron scanned 1,386 Gitea instances across seven countries and maintained a separate dataset of 477 Taiwan-based systems...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/09/red-heron-exploits-gitea-rce-to.html>

06. AI has outpaced the patching clock - here's what the industry needs to do
Five ways the industry can respond to the AI challenge.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/perspective/ai-has-outpaced-the-patching-clock-heres-what-the-industry-needs-to-do>

07. Beyond the CVE Count: The Real State of Vulnerability Management - Charles Loring - CSP #228

Beyond the CVE Count: The Real State of Vulnerability Management - Charles Loring - CSP #228

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/podcast-segment/14662-beyond-the-cve-count-the-real-state-of-vulnerability-management-charles-loring-csp-228>

08. ↗ Weekly Recap: Rogue AI Agents, WeChat Worm, PaperCut Attacks, AI Espionage, and Rootkits

AI keeps showing up in the wrong places. Attackers are using it to speed up exploits, test defenses, and automate more of the job. Some models are also crossing lines on their own. That is not a great combination. The rest of the week is more familiar: old bugs still working, fresh exploit chains, exposed systems, weak defaults, and simple paths that should...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/09/weekly-recap-rogue-ai-agents-wechat.html>

09. Perfect-10 GitLab bug under attack days after patch lands

CISA confirms active exploitation as watchTower spots miscreants probing internet-facing servers

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.theregister.com/security/2026/09/14/perfect-10-gitlab-bug-under-attack-days-after-patch-lands/5296176>

10. Human Attacker Hits Machine-Speed Exploitation of Marimo RCE

A human attacker exploited a Marimo RCE and reached an SSH bastion in eight seconds

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.infosecurity-magazine.com/news/human-attacker-machine-speed/>

Data Breach & Cybercrime (10)

01. Japan's Digital Agency says VPN flaw exposed 246,000 personnel records

Japan's Digital Agency has discovered a data breach that may have exposed around 246,000 record rows containing personal information of government employees. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/japans-digital-agency-says-vpn-flaw-exposed-246-000-personnel-records/>

02. Bitsight connects threat intelligence and exposure monitoring across the supply chain

Bitsight access to a broad risk dataset, combining threat intelligence and continuous exposure monitoring to help teams mitigate risk across the supply chain. "The surge in third-party-originating cybersecurity breaches demands a fundamental shift in how cybersecurity leaders and their teams manage third-party cybersecurity risks," said Gartner. "Cybersecur..."

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.helpnetsecurity.com/2026/09/14/bitsight-beacon/>

03. Personal, Financial Info Exposed in Revolut Data Breach

The company unintentionally disclosed users' information to a third party impersonating a government agency. The post Personal, Financial Info Exposed in Revolut Data Breach appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.securityweek.com/personal-financial-info-exposed-in-revolut-data-breach/>

04. 14th September - Threat Intelligence Report

For the latest discoveries in cyber research for the week of 14th September, please download our Threat Intelligence Bulletin. TOP ATTACKS AND BREACHES IDScan.net, a US identity verification provider, has disclosed a data breach after detecting unauthorized access on September 1. Exposed data included names and government identification numbers, while a cri...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://research.checkpoint.com/2026/14th-september-threat-intelligence-report/>

05. Webinar: How malicious OAuth apps can lead to Google Workspace breaches

Attackers can combine social engineering with malicious OAuth applications to gain access to Google Workspace data without relying solely on stolen passwords. This webinar examines two attacks to show how these breaches unfold and which security controls can help stop them. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/webinar-how-malicious-oauth-apps-can-lead-to-google-workspace-breaches/>

06. Revolut Confirms Data Breach Through Fake Government Requests

An unauthorized party used a legitimate government email domain to fraudulently request Revolut customer data

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.infosecurity-magazine.com/news/revolut-data-breach-fake-government/>

07. [+24h Old] Telus Warns Customers of Account Breaches

Stolen credentials were used in a multi-month campaign to access subscriber personal data and billing records. The post Telus Warns Customers of Account Breaches appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.securityweek.com/telus-warns-customers-of-account-breaches/>

08. [+24h Old] Revolut discloses data breach exposing financial info, passports

Fintech company Revolut has disclosed a data breach after sharing data from an undisclosed number of customers with a threat actor impersonating a government agency. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/revolut-discloses-data-breach-exposing-financial-info-passports/>

09. [+24h Old] Malicious Twitch Browser Extension Leaks OAuth Tokens From Nearly 31,000 Users

A malicious cross-store Twitch browser extension has leaked OAuth tokens associated with nearly 31,000 users to proxy servers operated by a Russian commercial bot service. The extension, named "Twitch Enhanced Viewer | JeetBot," lists HISHIMIRO/jeetbot.cc as its developer and has the following identifiers on the Google Chrome Web Store and Mozilla Firefox A...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://thehackernews.com/2026/09/malicious-twitch-browser-extension.html>

10. [+24h Old] What we know about the Revolut data breach so far

Someone impersonating a government agency, using an email address on that agency's domain, obtained sensitive customer records from Revolut. The bank confirmed the incident on Saturday, September 12. The London-based fintech told TechCrunch that a limited number of customers were affected and that it had contacted them directly. The notification Revolut ema...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.helpnetsecurity.com/2026/09/14/revolut-data-breach-privacy/>